WALKER PRESS

CompTIA Security+ SY0-701

Practice Exam 2 of 5

90 Questions | 90 Minutes | Passing score 750 on a scale of 100–900

• This practice exam mirrors the format of the CompTIA Security+ SY0-701 certification exam: a maximum of 90 questions in 90 minutes.
• CompTIA reports the passing score as 750 on a scale of 100 to 900. That scale is CompTIA's own and is not a percentage of correct answers, so this document does not print a pass mark of its own. Use the Answer Key to find the objectives that need another evening.
• Questions are weighted by domain as on the real exam: General Security Concepts 12%, Threats, Vulnerabilities, and Mitigations 22%, Security Architecture 18%, Security Operations 28%, Security Program Management and Oversight 20%.
• Question types include Multiple Choice, Select Two/Three, Matching and Ordering. For Matching questions, pair each item with the best description. For Ordering questions, arrange the items in the correct sequence.
• The Answer Key with a full explanation for every question is at the end of this document.

www.walker-press.com

Questions

Question 1 [Multiple Choice]

Which of the following wireless denial-of-service techniques uses Layer 1 radio-frequency interference rather than manipulating 802.11 frames or protocol fields?

A. Jamming
B. RTS/CTS replay attack
C. Duration field values attack
D. Disassociation attack

Question 2 [Multiple Choice]

Borysko needs to specify which devices need to be included in the next vulnerability scan. What parameter must he set?

A. NET-SCAN
B. Scope
C. Sensitivity level
D. Region

Question 3 [Multiple Choice]

Your organization is developing its first business continuity plan. What is the FIRST step?

A. Perform a business impact analysis
B. Review lessons learned
C. Develop technical playbooks
D. Conduct employee training

Question 4 [Multiple Choice]

Which of the following is NOT a common network device that can be configured to provide a degree of security protection?

A. Router
B. Firewall
C. Switch
D. Endpoint

Question 5 [Matching]

Match each concept to its appropriate CIA Triad component.

Note: the same description may apply to more than one item.

Items	Descriptions
1. Data encryption	**A.** Integrity
2. System uptime monitoring	**B.** Confidentiality
3. Access control lists that restrict read access to sensitive files	**C.** Availability
4. File integrity checking	

Question 6 [Multiple Choice]

What is the primary difference between whitelisting and blacklisting applications?

- **A.** Whitelisting allows only explicitly approved apps
- **B.** Blacklisting is more secure
- **C.** Whitelisting blocks known bad apps only
- **D.** Blacklisting restricts apps based on file size

Question 7 [Multiple Choice]

A junior admin accidentally granted full disk access to a guest user. Which principle was most clearly violated?

- **A.** Least privilege
- **B.** Zero trust
- **C.** Separation of duties
- **D.** Defense in depth

Question 8 [Matching]

Assign each item to the correct control category.

Items	Descriptions
1. A next-generation firewall filtering traffic	**A.** Deterrent: discourages an attacker from acting
2. Approving a risk assessment and security policy	**B.** Operational: day-to-day tasks carried out by people
3. Help-desk staff verifying a caller's identity before resetting a password, per procedure	**C.** Managerial: policies, planning, and risk oversight
4. Chain-link fencing around the perimeter	**D.** Compensating: a stand-in for an unavailable control
	E. Physical: tangible barriers protecting facilities
	F. Technical: enforced by hardware or software

Question 9 [Multiple Choice]

Which compliance standard is focused on cardholder data security?

- **A.** PCI DSS
- **B.** HIPAA
- **C.** GDPR
- **D.** FISMA

Question 10 [Multiple Choice]

Aristide is explaining to a coworker the new cybersecurity asset management (CAM) system. Which of the following would he NOT say about a CAM?

- **A.** It can identify assets on a continuous and real-time basis.
- **B.** It can use vulnerability scanners.
- **C.** It is designed to replace asset management.
- **D.** It is a relatively new process that combines asset management with information security.

Question 11 [Multiple Choice]

A senior vice president of finance receives a deceptive email directing the recipient to a fake sign-in page designed to steal credentials. Which human-vector attack is this?

A. Phishing
B. Smishing
C. Vishing
D. Watering hole

Question 12 [Matching]

Match each documentation type with its purpose.

Items	Descriptions
1. SOP	**A.** Defines service performance expectations
2. Risk register	**B.** Lists and tracks organizational risks
3. SLA	**C.** Step-by-step operational guidance
4. DRP	**D.** Plans for recovery after disruption

Question 13 [Multiple Choice]

What is the primary role of a jump server in a secure architecture?

A. Isolate administrative access to critical systems
B. Patch and rebuild the running cloud container images
C. Filter inbound email attachments and embedded links
D. Enforce mobile device enrollment and compliance policies

Question 14 [Multiple Choice]

Which CVSS metric indicates how easily a vulnerability can be exploited?

A. Temporal score
B. Base score
C. Impact score
D. Exploitability subscore

Question 15 [Multiple Choice]

Fill in the blank: _____ is a type of attack where malicious code is inserted into a trusted website to target its visitors.

A. Phishing
B. Social engineering
C. SQL injection
D. Cross-site scripting (XSS)

Question 16 [Multiple Choice]

An organization needs an alternate site that already has power, network connectivity, and server hardware installed, but data must be restored from backups before operations can resume. The budget does not allow a fully synchronized duplicate facility. Which site type should the organization select?

A. Hot site
B. Warm site
C. Cold site
D. Geographically dispersed mirror site

Question 17 [Multiple Choice]

A system was compromised but restored using a gold image. Which response phase does this represent?

A. Lessons learned
B. Eradication
C. Recovery
D. Detection

Question 18 [Select Two]

A security architect is labeling controls by type. Which TWO of the following are preventive controls? (Select TWO.)

A. Restoring data from backup
B. Security camera footage review
C. Intrusion detection system alerts
D. Multifactor authentication at login
E. Disk encryption on laptops

Question 19 [Multiple Choice]

Fill in the blank: The _____ score provides a standardized way to prioritize software vulnerabilities.

A. CVSS
B. NIST score
C. CVE
D. CWE

Question 20 [Multiple Choice]

A company accepts a low-risk vulnerability due to the cost of fixing it. This is an example of:

A. Risk mitigation
B. Risk transfer
C. Risk avoidance
D. Risk acceptance

Question 21 [Multiple Choice]

An employee intentionally exfiltrates sensitive organizational data to support an ideological cause. Which security awareness topic most directly addresses this risk?

A. Password management
B. Insider threat
C. Hybrid/remote work environments
D. Removable media and cables

Question 22 [Multiple Choice]

Which of the following would BEST support the recovery phase of incident response?

A. Snapshot-based backups
B. Privilege auditing
C. Immutable logs
D. File integrity monitoring

Question 23 [Multiple Choice]

Which term specifically describes a vulnerability scan conducted from outside the target organization's network perimeter?

- **A.** Remote vulnerability scan
- **B.** Internal vulnerability scan
- **C.** External vulnerability scan
- **D.** Network vulnerability scan

Question 24 [Multiple Choice]

Which of the following is NOT correct about governance?

- **A.** Governance involves reporting on performance toward achieving intended results and then using that performance information to drive ongoing improvements and corrective actions.
- **B.** Governance is not concerned with overseeing the delivery of services; the implementation of its policies, plans, programs, and projects; and the monitoring and mitigation of risks.
- **C.** Governance is involved in assigning decision-making responsibilities, defining how decisions are to be made, and establishing the organization's strategic direction.
- **D.** Governance refers to the structures, systems, and practices an organization has in place to assign, oversee, and report.

Question 25 [Multiple Choice]

Which of the following scenarios BEST illustrates the concept of "least privilege"?

- **A.** Marketing staff granted access to sales pipeline and invoicing tools
- **B.** Developers running code with administrative rights
- **C.** A user given access only to the specific files needed for their job
- **D.** The helpdesk team with unrestricted access to all user mailboxes

Question 26 [Multiple Choice]

An unknown caller claims to be a senior vice president and requests a password reset, relying on the caller's claimed executive rank to gain compliance. Which principle of human manipulation is being used?

- **A.** Fright
- **B.** Urgency
- **C.** Intimidation
- **D.** Authority

Question 27 [Matching]

Match each endpoint protection technique with its goal.

Items	Descriptions
1. Application allowlisting	**A.** Prevent execution of unapproved programs
2. EDR	**B.** Close known software vulnerabilities
3. Antivirus	**C.** Remove known malware
4. Patch management	**D.** Detect and contain advanced threats

Question 28 [Matching]

Match each malware type to its behavior.

Items	Descriptions
1. Worm	**A.** Replicates itself without needing a host file
2. Rootkit	**B.** Locks or encrypts files for payment
3. Ransomware	**C.** Displays unwanted promotional content
4. Adware	**D.** Conceals administrative access and hides its presence

Question 29 [Multiple Choice]

What does a Business Impact Analysis (BIA) help identify?

- **A.** The impact of disruption on critical functions
- **B.** Organizational structure gaps
- **C.** Vulnerabilities in encryption protocols
- **D.** All open network ports

Question 30 [Matching]

Match each policy type to its focus.

Items	Descriptions
1. Clean desk	**A.** Regulates personal device usage
2. BYOD	**B.** Ensures physical confidentiality
3. Data retention	**C.** Controls storage timelines
4. Separation of duties	**D.** Divides critical tasks among multiple people to prevent unchecked control

Question 31 [Multiple Choice]

What is the MOST effective way to prevent data loss due to ransomware?

- **A.** Maintain offline backups
- **B.** Require strong passwords
- **C.** Encrypt user data
- **D.** Block USB ports

Question 32 [Multiple Choice]

What kind of control is enforced by implementing regular role rotations among privileged users?

- **A.** Technical
- **B.** Detective
- **C.** Administrative
- **D.** Physical

Question 33 [Multiple Choice]

Which of the following is NOT a challenge of running a vulnerability scan?

A. Low volume of scan data
B. Working within scanner technical limitations
C. Prioritizing remediation efforts
D. Reviewing false positives

Question 34 [Multiple Choice]

After patching a web server, an administrator runs a credentialed vulnerability rescan, which reports no remaining findings, and the ticket is closed. Two weeks later, an external penetration tester exploits the same vulnerability on that server because the patch never applied correctly. Which analysis outcome BEST describes the rescan result?

A. A false positive
B. A true positive
C. A false negative
D. A true negative

Question 35 [Multiple Choice]

Which of the following is NOT a response to risk?

A. Accept
B. Avoid
C. Mitigate
D. Resist

Question 36 [Multiple Choice]

Nollaig finds that an attacker submitted a URL containing repeated ../ sequences to access confidential files stored outside a web server's root directory. What type of attack was this?

A. Privilege escalation
B. Race condition
C. Directory traversal
D. Buffer overflow

Question 37 [Multiple Choice]

Scenario: Your SIEM flags repeated failed login attempts on a database server outside business hours. What is the MOST appropriate next step?

A. Isolate the affected server
B. Reset all credentials
C. Initiate an incident investigation
D. Disable the database

Question 38 [Select Two]

Which of the following are examples of detection controls? (Select TWO)

A. Antivirus quarantine
B. Security camera recording
C. Security awareness training
D. Log analysis tool
E. Intrusion prevention system

Question 39 [Matching]

Match each control type to its purpose.

Items	Descriptions
1. Preventive	**A.** Restores a system to normal
2. Detective	**B.** Used when the primary control is too costly
3. Corrective	**C.** Alerts when a policy is violated
4. Compensating	**D.** Stops unauthorized access

Question 40 [Multiple Choice]

Which of the following BEST illustrates the principle of separation of duties?

A. A finance manager approves and pays invoices
B. The same user writes and deploys production code
C. Developers push patches directly into production
D. One admin handles backups while another restores them

Question 41 [Multiple Choice]

Which of the following is NOT correct about forwarding emails?

A. Authorized forwarding to internal recipients may be permitted by corporate policy.
B. Employees should auto-forward corporate email to personal or external accounts for enhanced spam filtering.
C. External auto-forwarding can reduce organizational control over preserving email as evidence.
D. Messages forwarded to unmanaged accounts could become accessible to unauthorized users.

Question 42 [Matching]

A risk manager is training a new analyst on the fields used in the organization's risk register and quantitative analysis. Match each term to its definition.

Items	Descriptions
1. Key risk indicator	**A.** Level of risk above which escalation or treatment becomes mandatory
2. Risk owner	**B.** Risk that remains after the selected controls have been applied
3. Risk threshold	**C.** Metric tracked over time that warns when a risk is approaching an unacceptable level
4. Annualized rate of occurrence	**D.** Overall level of risk the organization is willing to pursue in order to meet its objectives
5. Exposure factor	**E.** Person accountable for deciding how a specific risk is treated and for its status
	F. Percentage of an asset's value expected to be lost in a single event
	G. Estimated number of times a specific loss event is expected to happen in a year

Question 43 [Multiple Choice]

An organization wants to reduce risk by identifying and remediating software vulnerabilities before deployment. What process should they implement?

A. EDR
B. Deprovisioning
C. Secure SDLC
D. Threat hunting

Question 44 [Matching]

Match each identity term to its definition.

Items	Descriptions
1. Provisioning	**A.** Disabling access after termination
2. Deprovisioning	**B.** Central login for multiple services
3. SSO	**C.** Cross-organization authentication
4. Federation	**D.** Initial creation of user access

Question 45 [Multiple Choice]

An organization's governing board requires its security policies and control standards to account for local legal requirements. This requirement is part of which security program element?

A. Risk mitigation
B. Asset classification
C. Governance
D. Due diligence

Question 46 [Matching]

Match each framework to its focus area.

Items	Descriptions
1. NIST CSF	**A.** Financial controls and reporting
2. ISO 27001	**B.** Information security management system standards
3. SOX	**C.** Health information privacy
4. HIPAA	**D.** Cybersecurity best practices for critical infrastructure

Question 47 [Multiple Choice]

Fill in the blank: A _____ defines how long data can be unavailable before affecting business continuity.

A. MTTR (Mean Time To Repair)
B. RTO (Recovery Time Objective)
C. MTBF (Mean Time Between Failures)
D. RPO (Recovery Point Objective)

Question 48 [Multiple Choice]

Which concept involves managing infrastructure through machine-readable configuration files?

- **A.** Virtualization
- **B.** SDN
- **C.** Containerization
- **D.** IaC (Infrastructure as Code)

Question 49 [Multiple Choice]

Which method is most effective for preventing phishing attacks?

- **A.** Enforcing browser sandboxing
- **B.** Conducting regular user awareness training
- **C.** Encrypting email attachments
- **D.** Installing a host-based firewall

Question 50 [Multiple Choice]

Fill in the blank: The _____ outlines expected service levels and responsibilities between a provider and a customer.

- **A.** NDA
- **B.** SLA
- **C.** BPA
- **D.** MOU

Question 51 [Multiple Choice]

Fill in the blank: A _____ document defines how an organization meets its legal and ethical responsibilities.

- **A.** Business impact analysis
- **B.** Policy review
- **C.** Risk assessment
- **D.** Code of conduct

Question 52 [Matching]

Match each wireless security protocol with its characteristic.

Items	Descriptions
1. WPA2	**A.** Most secure with SAE and forward secrecy
2. WPA3	**B.** Uses RC4 encryption; considered outdated and insecure
3. WEP	**C.** Uses AES encryption with pre-shared key
4. Open	**D.** Unencrypted access

Question 53 [Matching]

Match each malware type with its behavior.

Items	Descriptions
1. Rootkit	**A.** Replicates through networks without user action
2. Adware	**B.** Shows unsolicited promotional content
3. Worm	**C.** Steals user activity silently
4. Spyware	**D.** Embeds itself to gain administrative access

Question 54 [Multiple Choice]

Akari has been asked to install a packet analysis tool on a Linux web server. Because this server does not do anything unnecessary so it reduces the footprint that a threat actor could exploit, all applications on the server are command-line applications and there is no graphical user interface (GUI). Which tool would Akari install?

A. Ethereal
B. Tcpdump
C. Sniffer
D. Network General

Question 55 [Ordering]

Arrange the change-management steps in the order an organization should perform them.

Place the following in the correct order:

A. Implement the change during the maintenance window
B. Test the change in a staging environment
C. Update documentation and conduct a post-change review
D. Submit a formal change request
E. Obtain change advisory board approval
F. Perform impact analysis

Question 56 [Multiple Choice]

Fill in the blank: _____ refers to the process of recording who handled digital evidence and when.

A. Evidence log
B. Forensic timeline
C. Chain of custody
D. Incident report

Question 57 [Multiple Choice]

Two servers that have never shared a secret must agree on a symmetric session key across an untrusted network without an eavesdropper learning it. Which cryptographic approach makes this possible?

A. Steganography
B. Hashing
C. Asymmetric key exchange
D. Symmetric encryption

Question 58 [Multiple Choice]

After a server experiences a hardware failure, a company replaces the failed component and restores its data from backup to return it to normal operation. What kind of control is this?

A. Preventive
B. Corrective
C. Detective
D. Physical

Question 59 [Multiple Choice]

Fill in the blank: The duplication of critical components so that a backup component can take over after a failure is called _____.

A. Redundancy
B. Encryption
C. Load balancing
D. VPN tunnel

Question 60 [Multiple Choice]

Fill in the blank: The process of confirming a user's identity is known as _____.

A. Authentication
B. Encryption
C. Accounting
D. Authorization

Question 61 [Multiple Choice]

Which type of cyberattack involves sending crafted queries to manipulate backend databases?

A. Cross-site scripting
B. DNS poisoning
C. SQL injection
D. URL spoofing

Question 62 [Matching]

Match each attack type to its method.

Items	Descriptions
1. Pharming	**A.** Redirecting traffic using DNS poisoning
2. Vishing	**B.** Registering a domain similar to a legitimate one
3. Logic bomb	**C.** Malicious script triggered by a condition
4. Typosquatting	**D.** Social engineering via phone

Question 63 [Multiple Choice]

What is the primary goal of a Business Continuity Plan (BCP)?

A. Ensure ongoing operations during and after a crisis
B. Monitor patch compliance across endpoints
C. Reduce employee turnover in the IT and security teams
D. Identify exploitable vulnerabilities in production hosts

Question 64 [Multiple Choice]

Which of the following MOST helps minimize third-party risk?

A. Security awareness training
B. Whitelisting
C. Traffic shaping
D. Supply chain auditing

Question 65 [Multiple Choice]

Which of the following attacks transfers the data from one RFID tag to another?

A. RFID duplicating
B. RFID mirroring
C. RFID cloning
D. RFID swiping

Question 66 [Ordering]

A company is purchasing a new database server that will hold customer records. Arrange the asset management activities in the order they occur across the server's lifecycle.

Place the following in the correct order:

A. Sanitize the storage media so that no customer data can be recovered
B. Track the server's location, patch level, and configuration while it is in service
C. Assign an owner and classify the data the server will hold
D. Procure the server through the approved acquisition process
E. Obtain a certificate of destruction from the disposal vendor and update the records

Question 67 [Multiple Choice]

An attacker tricks a user into visiting a malicious site by mimicking a trusted domain. What type of attack is this?

A. Command injection
B. Typo-squatting
C. ARP spoofing
D. Session replay

Question 68 [Multiple Choice]

Which Zero Trust control-plane component evaluates access requests and makes policy decisions?

A. Policy Enforcement Point
B. Subject/System
C. Policy Engine
D. Implicit trust zone

Question 69 [Multiple Choice]

Which of the following describes a script kiddie?

A. A skilled hacker working for a nation-state
B. An insider using custom exploits
C. An unskilled attacker using pre-built tools
D. A hacktivist promoting political change

Question 70 [Multiple Choice]

What is the purpose of a chain of custody document in a forensic investigation?

A. Schedule patch timelines
B. Track incident trends
C. Encrypt audit logs
D. Document evidence handling

Question 71 [Multiple Choice]

A security team is deploying a zero trust model. Which of the following best aligns with this strategy?

A. Disable multifactor authentication for internal users
B. Require re-authentication when accessing each new resource
C. Allow access once users are inside the corporate LAN
D. Whitelist all known MAC addresses

Question 72 [Multiple Choice]

In a public key infrastructure (PKI), which component acts as an intermediary between the certificate applicant and the certificate authority, verifying the applicant's identity and credentials before the certificate is issued?

A. Certificate authority (CA)
B. Certificate signing request (CSR)
C. Intermediate CA
D. Registration authority (RA)

Question 73 [Multiple Choice]

Which of the following virtualizes parts of a physical local network?

A. VDI
B. SDN
C. SD-WAN
D. SDV

Question 74 [Multiple Choice]

Which WPA3 security feature is designed to increase security at the time of the handshake?

A. WEP
B. PXF
C. OWE
D. SAE

Question 75 [Multiple Choice]

A security team installs a honeypot that mimics a vulnerable server. What is the primary purpose of this configuration?

A. Segment VLAN traffic
B. Block all attackers
C. Provide threat intelligence
D. Restore data backups

Question 76 [Multiple Choice]

Which of the following is an example of a threat vector?

- **A.** Email phishing link
- **B.** Firewall appliance
- **C.** CVSS
- **D.** Password policy

Question 77 [Matching]

Match each port number to its corresponding protocol.

Items	Descriptions
1. 443	**A.** SSH
2. 22	**B.** RDP
3. 53	**C.** HTTPS
4. 3389	**D.** DNS

Question 78 [Multiple Choice]

During capacity planning for a new file server, Shai's organization prioritizes maximum boot and file read/write responsiveness over cost and storage capacity. Which configuration best meets this requirement?

- **A.** Boot from HDD and store data on SSD
- **B.** Boot from SSD and store data on SSD
- **C.** Boot from SSD and store data on HDD
- **D.** Boot from HDD and store data on HDD

Question 79 [Multiple Choice]

Fill in the blank: The _____ value in CVSS reflects how easily a vulnerability can be exploited.

- **A.** Exploitability
- **B.** Buffer overflow
- **C.** SQL injection
- **D.** Social engineering

Question 80 [Multiple Choice]

What does the term "serverless" mean in cloud computing?

- **A.** The cloud network configuration does not require any servers
- **B.** All appliances are virtual and do not interact with physical servers
- **C.** Server resources of the cloud are inconspicuous to the end-user
- **D.** Servers are run as VMs

Question 81 [Multiple Choice]

An organization evaluates a third-party SaaS provider’s documented security policies, procedures, and compliance posture before signing a contract. What is this process called?

- **A.** Digital forensics
- **B.** Vendor risk management
- **C.** Threat hunting
- **D.** Vulnerability assessment

Question 82 [Multiple Choice]

Which type of malware spreads across a network without requiring user interaction?

A. Worm
B. Trojan
C. Spyware
D. Rootkit

Question 83 [Multiple Choice]

A systems team built a hardened server image from an industry benchmark and pushed it to every server with Group Policy. Six months later, an audit finds unauthorized services running and registry settings that no longer match the image, and nobody had been notified. Which secure-baseline activity did the team fail to carry out?

A. Establishing the baseline from a recognized benchmark
B. Maintaining the baseline by monitoring for configuration drift
C. Sandboxing the servers so that new services cannot be installed
D. Deploying the baseline through centralized configuration tools

Question 84 [Multiple Choice]

A penetration tester exploits a hypervisor flaw that lets code running inside one guest virtual machine break out and reach the host and other guests. Which vulnerability class does this demonstrate?

A. Race condition
B. Virtual machine escape
C. Resource reuse
D. Directory traversal

Question 85 [Ordering]

Arrange the stages of a typical ransomware intrusion in the order they occur.

Place the following in the correct order:

A. Files are encrypted across the reachable systems
B. A user opens a phishing email attachment, giving initial access
C. A ransom demand is displayed
D. The malware executes and installs on the host
E. The attacker moves laterally to additional systems
F. The malware establishes a command-and-control channel

Question 86 [Multiple Choice]

Which of the following data security methods creates a copy of the original data but uses obfuscation on any sensitive elements?

A. Data masking
B. Data protecting
C. Data tokening
D. Data covering

Question 87 [Multiple Choice]

What is the main goal of a vulnerability scan?

A. Exploit system vulnerabilities
B. Block known threats
C. Identify misconfigurations and weaknesses
D. Prevent data exfiltration

Question 88 [Multiple Choice]

What kind of vulnerability allows attackers to inject unexpected code into a web form?

A. Input validation flaw
B. Packet sniffing
C. Cross-site request forgery
D. URL redirection

Question 89 [Multiple Choice]

Emiliano needs to determine the expected monetary loss every time a risk occurs. Which formula will he use?

A. SLE
B. ALE
C. ARO
D. AV

Question 90 [Multiple Choice]

Which of the following best defines a "false positive" in a security monitoring context?

A. A legitimate alert that analysts close without reviewing it
B. A real threat that the detection tool fails to catch
C. A benign activity incorrectly flagged as malicious
D. A phishing attempt that successfully steals a user's credentials

Answer Key

Each answer is followed by the reasoning behind it, including why the other options fall short.

Q1: A

B. RTS/CTS replay attack is incorrect because it abuses the 802.11 request-to-send/clear-to-send control-frame exchange to reserve the medium and starve legitimate stations, which is protocol manipulation rather than raw interference. C. Duration field values attack is incorrect because it forges inflated duration values so other stations set their network allocation vector and defer transmission, again abusing a protocol field. D. Disassociation attack is incorrect because it spoofs 802.11 management frames to disconnect clients from the access point. A. Jamming is correct: it floods the frequency band with radio noise at Layer 1, denying service through interference without touching 802.11 frames or fields.

Q2: B

C. Sensitivity level is incorrect. Sensitivity level controls the depth and intrusiveness of the scan (e.g., safe vs. aggressive checks), not which assets are included. D. Region is incorrect. Region is not a standard vulnerability scan parameter; it is not used to define which specific devices are targeted. B. Scope is correct. The scope parameter defines exactly which hosts, IP ranges, or network segments are included in the vulnerability scan, ensuring only authorized targets are assessed. A. NET-SCAN is incorrect. NET-SCAN is not a recognized vulnerability scanning parameter; it does not exist as a standard configuration option.

Q3: A

B. Review lessons learned is incorrect. Lessons learned reviews happen after an incident or after a BCP exercise — they require an existing plan and cannot be the starting point for building one. A. Perform a business impact analysis is correct. A BIA is the mandatory first step in BCP. It identifies critical business functions, their dependencies, and the financial and operational consequences of disruption — generating the RTO and RPO values that drive all subsequent recovery strategy decisions. D. Conduct employee training is incorrect. Training is essential but occurs after the plan exists — you cannot train people to execute a plan that hasn't been created yet. C. Develop technical playbooks is incorrect. Playbooks are procedural documents built after the BIA determines which functions need protection and at what recovery speed.

Q4: D

A. Router is incorrect because a router is a network device that can be configured with access control lists and traffic filtering to provide security protection. C. Switch is incorrect because a switch is a network device that supports protections such as port security and 802.1X authentication. D. Endpoint is correct because an endpoint (such as a workstation or mobile device) is a host that connects to the network; it is not a network device that provides security protection for network traffic. B. Firewall is incorrect because a firewall is the classic network device dedicated to filtering and protecting network traffic.

Q5: 1 = B; 2 = C; 3 = B; 4 = A

The correct mapping is: Data encryption maps to Confidentiality because it prevents unauthorized parties from reading sensitive data. System uptime monitoring maps to Availability because it ensures services remain accessible and downtime is detected promptly. Access control lists that restrict read access map to Confidentiality because they control who can view specific resources, preventing unauthorized disclosure. File integrity checking maps to Integrity because hash comparison detects unauthorized modifications, confirming data has not been altered. Note that both encryption and read-access ACLs support Confidentiality through different mechanisms.

Q6: A

B. Blacklisting is more secure is incorrect. Blacklisting only blocks known-bad items, so unknown or new malware can still run. C. Whitelisting blocks known bad apps only is incorrect. This reverses the model; blocking known-bad is blacklisting. A. Whitelisting allows only explicitly approved apps is correct. Application allowlisting (whitelisting) runs in default-deny mode, permitting execution only of applications that have been explicitly vetted and approved. D. Blacklisting restricts apps based on file size is incorrect. File size has no bearing on allow/deny decisions; listing is by application identity, not size.

Q7: A

A (Least privilege) is correct: granting a guest account full disk access hands it far more rights than its role could ever require, and least privilege demands that every account get only the minimum access needed for its job. B (Zero trust) is incorrect because zero trust is a broad architecture of continuous verification and no implicit trust; what failed here is the size of the grant, not the verification of a request. D (Defense in depth) is incorrect because that concerns layering multiple overlapping controls, and nothing in the scenario says other layers were removed. C (Separation of duties) is incorrect because it splits a sensitive process among several people to prevent fraud; a single over-broad permission was assigned, not a pair of conflicting duties.

Q8: 1 = F; 2 = C; 3 = B; 4 = E

1 → F (Technical): a next-generation firewall enforces protection through technology. 2 → C (Managerial): approving a risk assessment and security policy is governance and oversight of the program. 3 → B (Operational): help-desk staff following a documented identity-verification procedure before a password reset is a day-to-day task carried out by people. 4 → E (Physical): chain-link fencing is a tangible barrier protecting the facility. Unused: D (Compensating) — no substitute-for-a-missing-control is shown; A (Deterrent) — deterrent is a control type, not one of the four categories being sorted here.

Q9: A

C. GDPR is incorrect. The General Data Protection Regulation governs the privacy of personal data of individuals in the EU, not payment card data specifically. D. FISMA is incorrect. The Federal Information Security Management Act sets security requirements for U.S. federal government information systems. A. PCI DSS is correct. The Payment Card Industry Data Security Standard is the industry standard that defines how organizations must protect cardholder data when they store, process, or transmit payment card information. B. HIPAA is incorrect. The Health Insurance Portability and Accountability Act protects the privacy and security of health information, not cardholder data.

Q10: C

C (It is designed to replace asset management.) is correct: the question asks what Aristide would NOT say, and this statement is false. Cybersecurity asset management (CAM) does not replace traditional asset management; it builds on it by adding a security perspective so that every hardware, software, and data asset is not only tracked but also assessed for risk. D (It is a relatively new process that combines asset management with information security.) is incorrect as an answer because that is exactly what CAM is. A (It can identify assets on a continuous and real-time basis.) is incorrect as an answer because CAM continuously discovers and monitors connected devices. B (It can use vulnerability scanners.) is incorrect as an answer because CAM draws on vulnerability scanners and similar tools to enumerate assets and identify their weaknesses.

Q11: A

C. Vishing is incorrect because it is conducted through voice calls, not email. B. Smishing is incorrect because it uses SMS text messages as the delivery vector, not email. D. Watering hole is incorrect because that attack compromises a legitimate website the intended victims routinely visit; it does not start with a deceptive email. A. Phishing is correct: a deceptive email that directs the recipient to a fake sign-in page to steal credentials is a classic phishing attack.

Q12: 1 = C; 2 = B; 3 = A; 4 = D

The correct pairings are: SOP = Step-by-step operational guidance; Risk register = Lists and tracks organizational risks; SLA = Defines service performance expectations; DRP = Plans for recovery after disruption. An SOP (Standard Operating Procedure) provides detailed, sequential instructions for performing specific tasks consistently and in compliance with policy. A risk register is a living document recording identified risks along with their likelihood, impact rating, owner, and treatment status. An SLA (Service Level Agreement) defines measurable performance commitments — such as 99.9% uptime or 4-hour support response — between a provider and customer. A DRP (Disaster Recovery Plan) documents procedures to restore IT systems and data after a major outage or disaster.

Q13: A

C. Filter inbound email attachments and embedded links is incorrect. Attachment filtering is performed by a secure email gateway, not a jump server. D. Enforce mobile device enrollment and compliance policies is incorrect. Enrollment and device compliance are the role of an MDM or UEM platform, unrelated to a jump server. A. Isolate administrative access to critical systems is correct. A jump server (jump box) is a hardened, monitored host that administrators must connect through to reach sensitive systems, creating a single controlled chokepoint for privileged access. B. Patch and rebuild the running cloud container images is incorrect. Container patching is handled by image build pipelines and orchestration, not by a jump server.

Q14: D

B. Base score is incorrect. The base score is the overall severity rating derived from combining exploitability and impact factors; it is not the specific measure of how easily the flaw can be exploited. C. Impact score is incorrect. The impact subscore reflects the consequences to confidentiality, integrity, and availability if the vulnerability is exploited, not the ease of exploitation. D. Exploitability subscore is correct. Within CVSS, the exploitability subscore captures how easily a vulnerability can be exploited, based on factors such as attack vector, attack complexity, privileges required, and user interaction. A. Temporal score is incorrect. The temporal metrics adjust severity over time for factors like exploit code maturity and remediation level; they do not define the baseline ease of exploitation.

Q15: D

C. SQL injection is incorrect. SQLi targets backend databases through malicious query input, not the browsers of site visitors. A. Phishing is incorrect. Phishing uses deceptive messages (email, SMS) to lure users; it does not typically inject code into a trusted website. B. Social engineering is incorrect. Social engineering is a broad human-targeting category, not a specific web attack. D. Cross-site scripting (XSS) is correct. XSS works by inserting malicious scripts into pages served by a trusted website; when other users visit the page, their browsers execute the script, enabling session theft or actions on behalf of the victim.

Q16: B

A. A hot site is incorrect because it is a fully equipped facility with near-real-time data replication, which exceeds the stated budget. B. A warm site is correct: it provides power, connectivity, and hardware already in place, while data is restored from backups at failover time, trading some downtime for lower cost. C. A cold site is incorrect because it offers only space and utilities, with no server hardware installed. D. A geographically dispersed mirror site is incorrect because a continuously synchronized duplicate facility is exactly the option the budget rules out.

Q17: C

D. Detection is incorrect. The detection phase involves identifying that a compromise has occurred — it precedes any remediation action. B. Eradication is incorrect. Eradication focuses on removing the malware, unauthorized accounts, or persistence mechanisms — it does not restore system functionality. C. Recovery is correct. The recovery phase involves restoring systems to a known-good state so normal operations can resume. Using a gold image (a verified clean baseline snapshot) to rebuild a compromised system is a textbook recovery activity. A. Lessons learned is incorrect. The lessons learned phase occurs after recovery; it involves reviewing what happened and improving controls to prevent recurrence.

Q18: D, E

E and D are correct: disk encryption prevents unauthorized disclosure of data before it can occur, and multifactor authentication prevents unauthorized logins by requiring more than a password. B is incorrect: reviewing security-camera footage identifies events after they happen, which is a detective control. C is incorrect: intrusion detection system alerts also detect activity after it begins rather than stopping it, so they are detective. A is incorrect: restoring data from backup repairs damage after an incident, which is a corrective control.

Q19: A

C. CVE is incorrect. CVE (Common Vulnerabilities and Exposures) assigns unique identifiers (e.g., CVE-2024-12345) to publicly known vulnerabilities — it names them but does not score their severity. D. CWE is incorrect. CWE (Common Weakness Enumeration) catalogs types of software weaknesses such as buffer overflow or SQL injection — it is a classification system, not a severity scoring mechanism. A. CVSS is correct. CVSS (Common Vulnerability Scoring System) provides a standardized numerical score from 0 to 10 based on exploitability, scope, and impact sub-metrics. Organizations and tools like the NVD use CVSS scores to prioritize which vulnerabilities to remediate first. B. NIST score is incorrect. While NIST's National Vulnerability Database publishes CVSS scores, 'NIST score' is not a recognized scoring system name.

Q20: D

B. Risk transfer is incorrect. Transferring risk shifts the financial impact to a third party, such as buying insurance or outsourcing the function; the company here is retaining the risk itself. C. Risk avoidance is incorrect. Avoidance eliminates the risk by not engaging in the activity at all; the organization continues to operate with the vulnerability in place. D. Risk acceptance is correct. When the cost of remediation outweighs the low potential impact, the organization consciously decides to live with the vulnerability rather than spend to fix it - the definition of accepting the risk. A. Risk mitigation is incorrect. Mitigation reduces the likelihood or impact by applying a control, but here no fix is applied because it is judged too costly.

Q21: B

B. Insider threat is correct: insider threat awareness covers harmful actions by people with authorized access, including an employee who intentionally exfiltrates data for an ideological cause. A. Password management is incorrect: it addresses creating and protecting credentials, not deliberate data theft by an authorized user. D. Removable media and cables is incorrect: that training topic addresses the risks of storage devices and untrusted cables, which is not the central issue in this scenario. C. Hybrid/remote work environments is incorrect: that guidance addresses the risks of working outside traditional offices, not intentional insider exfiltration.

Q22: A

C. Immutable logs are incorrect. Tamper-proof logs preserve evidence for analysis and investigation but do not restore systems or data to service. D. File integrity monitoring is incorrect. FIM detects unauthorized changes to files; it aids detection, not the restoration of operations. A. Snapshot-based backups are correct. The recovery phase aims to restore affected systems to normal operation; point-in-time snapshots let responders roll systems back to a known-good state quickly, directly supporting recovery. B. Privilege auditing is incorrect. Reviewing access rights supports prevention and detection of excessive permissions; it does not restore systems after an incident.

Q23: C

A. Remote vulnerability scan is incorrect. "Remote" only means the scanner does not run on the target host itself; a remote scan can also be launched from inside the network. C. External vulnerability scan is correct. It is the specific term for a scan launched from outside the organization's network perimeter, simulating an internet-based attacker's view of exposed services. D. Network vulnerability scan is incorrect. This describes what is being scanned (network devices and services), not the vantage point the scan is launched from. B. Internal vulnerability scan is incorrect. It is conducted from inside the perimeter to reveal what an insider or an attacker with a foothold could exploit.

Q24: B

B (Governance is not concerned with overseeing the delivery of services...) is correct: the question asks for the statement that is NOT true, and this one is false. Governance is the set of policies, procedures, roles, and responsibilities that oversee service delivery, the implementation of plans and programs, and the monitoring and mitigation of risk. D (Governance refers to the structures, systems, and practices...) is incorrect as an answer because it accurately describes governance structures such as boards and committees. C (Governance is involved in assigning decision-making responsibilities...) is incorrect as an answer because setting strategic direction and decision rights is a true governance function. A (Governance involves reporting on performance...) is incorrect as an answer because monitoring, revision, and corrective action are genuine elements of effective governance.

Q25: C

A. Marketing staff granted access to sales pipeline and invoicing tools is incorrect. Access beyond what the marketing role requires is excessive privilege, the opposite of least privilege. B. Developers running code with administrative rights is incorrect. Running with admin rights when not required grants more privilege than the task needs, violating least privilege. C. A user given access only to the specific files needed for their job is correct. Least privilege grants each user exactly the access required to perform their duties and nothing more, limiting the damage from compromise or misuse. D. The helpdesk team with unrestricted access to all user mailboxes is incorrect. Unrestricted access to every mailbox far exceeds what support tasks require, contradicting least privilege.

Q26: D

D. Authority is correct: the caller leverages a claimed senior executive position so the request is obeyed out of deference to rank. A. Fright is incorrect because it is not a recognized principle of human manipulation, and the caller relies on rank rather than provoking fear. C. Intimidation is incorrect because the caller issues no threat of negative consequences in this scenario; compliance is sought through position, not menace. B. Urgency is incorrect because the caller imposes no deadline or time pressure on the request.

Q27: 1 = A; 2 = D; 3 = C; 4 = B

The correct mapping is: Application allowlisting prevents execution of unapproved programs by maintaining a list of explicitly authorized applications — anything not on the list is blocked by default. EDR (Endpoint Detection and Response) detects and contains advanced threats through real-time behavioral monitoring, investigation, and automated response on endpoint devices. Antivirus removes known malware by comparing files against signature databases and quarantining or deleting matches. Patch management closes known software vulnerabilities by applying vendor-released updates, reducing the exploitable attack surface. Each tool targets a different layer of endpoint security.

Q28: 1 = A; 2 = D; 3 = B; 4 = C

The correct pairings are: Worm = Replicates itself without needing a host file; Rootkit = Conceals administrative access and hides its presence; Ransomware = Locks or encrypts files for payment; Adware = Displays unwanted promotional content. A worm is self-propagating malware that spreads across networks autonomously without attaching to a host file. A rootkit embeds deeply into the OS to hide its presence and maintain privileged (root-level) access, often masking other malware. Ransomware encrypts a victim's data and demands payment for the decryption key. Adware displays unsolicited advertisements, often bundled with free software, generating revenue for the attacker through clicks or impressions.

Q29: A

D. All open network ports is incorrect. Enumerating open ports is a function of network or vulnerability scanning, not of a BIA. B. Organizational structure gaps is incorrect. A BIA assesses the effect of disruptions on business functions, not gaps in the organizational chart. A. The impact of disruption on critical functions is correct. A Business Impact Analysis identifies critical business functions and processes and quantifies the operational and financial impact of their disruption, informing recovery priorities and objectives such as RTO and RPO. C. Vulnerabilities in encryption protocols is incorrect. Finding cryptographic weaknesses is the role of vulnerability assessments, not a BIA.

Q30: 1 = B; 2 = A; 3 = C; 4 = D

The correct mapping is: Clean desk ensures physical confidentiality by requiring employees to clear sensitive materials from their workspace when unattended, preventing unauthorized viewing. BYOD regulates personal device usage, defining security requirements for employee-owned phones, tablets, and laptops that access company resources. Data retention controls storage timelines, specifying how long data is stored and when it must be deleted to meet legal or operational requirements. Separation of duties divides critical tasks among multiple people so that no single individual has unchecked control over a sensitive process.

Q31: A

D. Block USB ports is incorrect. Disabling USB limits one infection and data-transfer vector but does nothing to recover files already encrypted by ransomware. C. Encrypt user data is incorrect. Encryption protects confidentiality; ransomware simply encrypts the already-encrypted files again, so it does not prevent data loss. A. Maintain offline backups is correct. Offline (or otherwise isolated/immutable) backups cannot be reached and encrypted by ransomware that spreads across the network, so clean copies remain available to restore data without paying a ransom — the most effective defense against ransomware data loss. B. Require strong passwords is incorrect. Strong passwords help resist credential attacks but do not ensure recoverable data once ransomware has encrypted it.

Q32: C

A. Technical is incorrect. Technical (logical) controls are enforced by technology such as firewalls or access-control software; a scheduled rotation of duties is a management practice, not a technical mechanism. C. Administrative is correct. Rotating roles among privileged users is a managerial and administrative control: a policy-driven procedure that reduces fraud and single-person dependency by periodically changing who holds sensitive duties. D. Physical is incorrect. Physical controls protect tangible assets and facilities (locks, guards, fences); role rotation involves no physical safeguard. B. Detective is incorrect. Detective controls identify events after they occur (logs, alerts); role rotation is a preventive administrative measure, not a detection mechanism.

Q33: A

C. Prioritizing remediation efforts is a genuine challenge — scans surface many findings that must be triaged and fixed with limited resources — so it is not the answer. B. Working within scanner technical limitations is a genuine challenge — scanners can miss issues behind segmentation, encryption, or missing credentials — so it is not the answer. D. Reviewing false positives is a genuine challenge — reported findings must be validated before acting on them — so it is not the answer. A. Low volume of scan data is correct because it is NOT a challenge: vulnerability scans typically generate large volumes of data that require significant time and expertise to analyze and prioritize.

Q34: C

C is correct (A false negative): the vulnerability was still present, but the scanner reported that it was gone. A false negative is the most dangerous confirmation error because it creates unwarranted confidence and closes remediation tickets while the exposure remains, which is why validation of remediation should combine rescanning with verification, such as checking the installed version or running a targeted test. A is incorrect (A false positive) because a false positive is a reported finding that turns out not to exist; here nothing was reported. B is incorrect (A true positive) because a true positive means the scanner correctly flagged a real weakness, but this scanner flagged nothing. D is incorrect (A true negative) because a true negative would mean the scanner correctly found no vulnerability, yet the penetration tester proved the flaw was still exploitable.

Q35: D

D (Resist) is correct: the question asks for the option that is NOT a recognized response to risk, and resist is not one of them. The SY0-701 risk management strategies are transfer, accept, avoid, and mitigate; an organization does not formally resist a risk, it chooses one of those four treatments after assessing likelihood and impact. C (Mitigate) is incorrect as an answer because mitigation is a genuine response in which controls such as firewalls, training, or segmentation reduce the likelihood or impact of the risk. A (Accept) is incorrect as an answer because acceptance is a genuine response in which the organization acknowledges the risk and takes no further action, typically when the cost of treatment exceeds the potential loss. B (Avoid) is incorrect as an answer because avoidance is a genuine response that eliminates the risk by discontinuing the activity that creates it.

Q36: C

C. Directory traversal is correct: repeated ../ sequences in a URL are the classic indicator of navigating outside the web root to reach files that should not be reachable. D. Buffer overflow is incorrect because it involves overrunning memory with oversized input, not crafted directory paths. B. Race condition is incorrect because it exploits time-of-check/time-of-use timing gaps, which the URL evidence does not show. A. Privilege escalation is incorrect because no account rights were elevated; the attacker abused path handling to read files.

Q37: C

D. Disable the database is incorrect. Taking the database offline would disrupt business operations and is disproportionate based solely on SIEM alerts without confirmed malicious activity. B. Reset all credentials is incorrect. Mass credential resets cause user disruption and may destroy forensic evidence before the scope of the breach is understood. A. Isolate the affected server is incorrect. Isolation is a containment step that comes after the incident has been investigated and confirmed — acting too quickly could disrupt evidence collection. C. Initiate an incident investigation is correct. Repeated failed logins outside business hours are suspicious indicators but not confirmed attacks. The proper first step is to open a formal investigation — reviewing authentication logs, correlating with other events, and determining whether the activity represents a real threat before taking disruptive action.

Q38: B, D

B and D are correct: B (Security camera recording) is correct because it is a detective control: recorded video does not stop an intruder, but it identifies that an event occurred and who was involved after the fact. D (Log analysis tool) is correct for the same reason: reviewing logs reveals security events such as failed logins or unusual traffic that have already happened. A (Antivirus quarantine) is incorrect because isolating a detected file is a corrective action that limits the damage of a threat, not merely a detection. E (Intrusion prevention system) is incorrect because an IPS sits in line and actively blocks malicious traffic, making it a preventive control; an IDS would be the detective counterpart. C (Security awareness training) is incorrect because training guides user behavior before an incident and is classified as a directive or preventive control.

Q39: 1 = D; 2 = C; 3 = A; 4 = B

The correct mapping is: Preventive controls stop unauthorized access before it occurs (e.g., firewalls, access controls). Detective controls alert when a policy is violated, identifying incidents after or during occurrence (e.g., IDS, log monitoring). Corrective controls restore a system to normal after an incident (e.g., restoring from backup, patching). Compensating controls are used as alternatives when the primary control is too costly or impractical to implement. Each type serves a distinct phase of the security lifecycle — prevention, detection, recovery, and substitution.

Q40: D

B. The same user writes and deploys production code is incorrect. Concentrating both writing and deploying in one person removes the checks that separation of duties is meant to create. A. A finance manager approves and pays invoices is incorrect. Letting one person both approve and pay concentrates a sensitive process in a single individual — the opposite of separation of duties. D. One admin handles backups while another restores them is correct. Separation of duties splits a critical task across two people so no single individual controls the entire process, reducing the risk of fraud or error; assigning backup and restore to different admins is a textbook example. C. Developers push patches directly into production is incorrect. Allowing developers to move their own changes straight to production bypasses independent review and does not separate the duties involved.

Q41: B

A. Stating that authorized forwarding to internal recipients may be permitted by corporate policy is accurate, so it is not the correct choice. B. Correct — this statement is NOT correct: employees should not auto-forward corporate email to personal or external accounts; doing so exposes sensitive information to unmanaged systems and typically violates security policy, regardless of any perceived spam-filtering benefit. C. It is true that external auto-forwarding can reduce the organization's control over preserving email as evidence, weakening forensic readiness, so it is not the correct choice. D. It is true that messages forwarded to unmanaged accounts could become accessible to unauthorized users, so it is not the correct choice.

Q42: 1 = C; 2 = E; 3 = A; 4 = G; 5 = F

1 → C (Metric tracked over time that warns when a risk is approaching an unacceptable level): a key risk indicator is an early-warning measurement, such as the number of unpatched critical systems, that shows a risk trending in the wrong direction. 2 → E (Person accountable for deciding how a specific risk is treated and for its status): the risk owner, usually a business or department head, has the authority to accept, mitigate, transfer, or avoid the risk. 3 → A (Level of risk above which escalation or treatment becomes mandatory): the risk threshold is the trigger point in the register that forces action or escalation. 4 → G (Estimated number of times a specific loss event is expected to happen in a year): ARO is the frequency term in the ALE calculation; an event expected every four years has an ARO of 0.25. 5 → F (Percentage of an asset's value expected to be lost in a single event): exposure factor is multiplied by asset value to produce the single loss expectancy. Unused: D (Overall level of risk the organization is willing to pursue in order to meet its objectives) — that defines risk appetite, set by leadership rather than recorded per risk; B (Risk that remains after the selected controls have been applied) — that is residual risk, an outcome of treatment rather than a register input.

Q43: C

D. Threat hunting is incorrect: it proactively searches for adversaries already in the environment, not for code flaws before deployment. C. Secure SDLC is correct: a secure software development lifecycle builds security into each phase (design, coding, testing) to identify and remediate vulnerabilities before software is deployed. A. EDR is incorrect: endpoint detection and response monitors running endpoints for threats, it does not review software during development. B. Deprovisioning is incorrect: it removes user access at offboarding and has nothing to do with software vulnerability remediation.

Q44: 1 = D; 2 = A; 3 = B; 4 = C

The correct mapping is: Provisioning is the initial creation of user access — creating accounts, assigning roles, and granting permissions when a user joins the organization. Deprovisioning disables access after termination — removing accounts and permissions promptly to prevent former employees from retaining access. SSO (Single Sign-On) enables central login for multiple services — users authenticate once and gain access to all connected applications. Federation enables cross-organization authentication — allowing users from one organization's identity provider to access resources in a partner organization without creating separate accounts. Each concept addresses a different phase or scope of identity lifecycle management.

Q45: C

B. Asset classification is incorrect: it categorizes data and systems by sensitivity and value; it does not establish the requirement that policies reflect legal obligations. D. Due diligence is incorrect: it is the investigation performed before a decision, such as vetting a vendor, not a standing board-level requirement on policies and standards. A. Risk mitigation is incorrect: it applies controls to reduce the likelihood or impact of specific risks rather than defining policy requirements. C. Governance is correct: security governance is where the board and senior leadership set direction and require policies and control standards to account for external considerations such as local legal requirements.

Q46: 1 = D; 2 = B; 3 = A; 4 = C

The correct pairings are: NIST CSF = Cybersecurity best practices for critical infrastructure; ISO 27001 = Information security management system standards; SOX = Financial controls and reporting; HIPAA = Health information privacy. NIST CSF was developed specifically to help operators of critical infrastructure manage cybersecurity risk through five core functions (Identify, Protect, Detect, Respond, Recover). ISO 27001 is an international standard that defines requirements for establishing and maintaining an Information Security Management System (ISMS). SOX (Sarbanes-Oxley Act) is a U.S. law enacted after financial scandals to strengthen internal controls over financial reporting. HIPAA (Health Insurance Portability and Accountability Act) protects the privacy and security of health information in the U.S.

Q47: B

D. RPO (Recovery Point Objective) is incorrect. RPO defines the maximum acceptable amount of data loss measured in time, not how long a system can be unavailable. B. RTO (Recovery Time Objective) is correct. The RTO is the maximum tolerable length of time a system or process can be down after a disruption before it unacceptably affects business continuity. C. MTBF (Mean Time Between Failures) is incorrect. MTBF is a reliability metric describing the average operating time between failures, not a downtime tolerance target. A. MTTR (Mean Time To Repair) is incorrect. MTTR is the average time taken to repair a failed component, a maintenance metric rather than a continuity threshold.

Q48: D

A. Virtualization is incorrect. Virtualization abstracts physical hardware into virtual machines but does not by itself mean defining infrastructure declaratively in code. D. IaC (Infrastructure as Code) is correct. IaC uses machine-readable configuration files (Terraform, CloudFormation, Ansible, etc.) to provision and manage infrastructure in a repeatable, version-controlled, and auditable way. C. Containerization is incorrect. Containerization packages applications and their dependencies into isolated runtime units; it is a deployment technology, not a method of managing infrastructure definitions. B. SDN is incorrect. Software-Defined Networking decouples the network control plane from data plane, which is related but narrower in scope than IaC.

Q49: B

D. Installing a host-based firewall is incorrect. A host firewall filters network connections and does not stop a user from being deceived by a phishing message. A. Enforcing browser sandboxing is incorrect. Sandboxing can contain malicious code execution but does not prevent a user from disclosing credentials to a convincing phishing site. B. Conducting regular user awareness training is correct. Because phishing targets human judgment, training users to recognize and report suspicious messages is the most effective countermeasure against it. C. Encrypting email attachments is incorrect. Encryption protects the confidentiality of legitimate attachments; it does nothing to prevent phishing attempts.

Q50: B

D. MOU is incorrect. A Memorandum of Understanding expresses general intent between parties and does not define measurable service levels. A. NDA is incorrect. A Non-Disclosure Agreement protects confidentiality of shared information and has no service-level clauses. B. SLA is correct. A Service Level Agreement formally defines the expected performance metrics (uptime, response time, penalties) and the responsibilities of both the provider and the customer. C. BPA is incorrect. A Business Partnership Agreement governs ownership, profit-sharing, and responsibilities between partners, not provider-customer service levels.

Q51: D

D. Code of conduct is correct. A code of conduct defines the ethical standards, values, and behavioral expectations that guide how an organization and its employees act — including how the organization fulfills its legal and ethical responsibilities to regulators, customers, and stakeholders. It formalizes commitments to integrity, compliance, and professional behavior. A. Business impact analysis is incorrect. A BIA identifies critical business functions and quantifies the impact of disruptions — it is a risk and continuity planning tool, not a governance ethics document. B. Policy review is incorrect. A policy review is a periodic process for evaluating whether existing policies remain accurate and effective — it is not a document type. C. Risk assessment is incorrect. A risk assessment identifies and evaluates threats and vulnerabilities to determine risk exposure — it is an analytical activity, not a document that articulates legal and ethical commitments.

Q52: 1 = C; 2 = A; 3 = B; 4 = D

The correct mapping is: WPA2 → uses AES encryption with a pre-shared key, the widely deployed standard that replaced WPA/TKIP. WPA3 → the most secure current standard, adding SAE authentication and forward secrecy so past sessions stay protected even if a password is later compromised. WEP → uses RC4 encryption with weak initialization vectors; it is cryptographically broken, considered outdated and insecure, and must never be used. Open → unencrypted access with no authentication, leaving all traffic visible to anyone in range. Note that TKIP was the interim fix introduced with WPA (not WEP) and is itself deprecated.

Q53: 1 = D; 2 = B; 3 = A; 4 = C

The correct mapping is: Rootkit embeds itself deeply in the OS to gain and maintain administrative (root) access while concealing its presence from security tools. Adware shows unsolicited promotional content, generating revenue for the attacker through forced ad impressions. Worm replicates itself across networks without requiring user interaction or a host file. Spyware silently monitors user activity — keystrokes, browsing, credentials — and transmits data to the attacker. Each type has a distinct persistence and impact profile that Security+ candidates must distinguish.

Q54: B

B (Tcpdump) is correct: tcpdump is a command-line packet capture and analysis tool that ships with or is easily installed on Linux. It runs entirely from the terminal, so it fits a hardened web server that has no graphical interface and a deliberately minimal footprint, and its captures can later be opened in Wireshark elsewhere if deeper analysis is needed. A (Ethereal) is incorrect because Ethereal was the former name of Wireshark, a graphical protocol analyzer that requires a GUI and would add unnecessary software to the server. D (Network General) is incorrect because it is the name of a company that sold commercial network analysis products, not a lightweight command-line tool for Linux. C (Sniffer) is incorrect because sniffer is a generic term for any packet capture tool and was also a commercial GUI product; it is not the specific command-line utility Akari needs.

Q55: D > F > E > B > A > C

Correct order: 1. Submit a formal change request — this initiates the process with a documented objective and justification. 2. Perform impact analysis — evaluate the technical and business consequences, including downtime and risk. 3. Obtain change advisory board approval — stakeholders sign off before any work begins. 4. Test the change in a staging environment — validate it safely before touching production. 5. Implement the change during the maintenance window — deploy at a low-impact time with a rollback ready. 6. Update documentation and conduct a post-change review — record what changed and capture lessons learned.

Q56: C

C (Chain of custody) is correct: chain of custody is the documented trail that records who collected, handled, transferred, and stored digital evidence, and exactly when each hand-off occurred. It is maintained with timestamps, signatures, hashes, and tamper-evident containers so the evidence can be shown to be unaltered and admissible if legal action follows. A (Evidence log) is incorrect because it is not the recognized term; a log of items may exist, but the formal record of handling and custody transfers is the chain of custody. D (Incident report) is incorrect because an incident report summarizes what happened, the impact, and the response; it does not track the handling of individual pieces of evidence. B (Forensic timeline) is incorrect because a timeline reconstructs the sequence of the attacker's actions from artifacts, not the sequence of people who handled the evidence.

Q57: C

C is correct (Asymmetric key exchange): public-key methods let two parties establish a shared symmetric key over an untrusted channel without transmitting the secret itself. D is incorrect (Symmetric encryption): symmetric encryption requires both parties to already hold the same secret key, which is the very problem being solved. B is incorrect (Hashing): hashing is a one-way function for integrity and cannot be used to share or recover a key. A is incorrect (Steganography): steganography hides the existence of data within other data and provides no key-agreement capability.

Q58: B

C. Detective is incorrect. Detective controls identify and alert that an incident has occurred (e.g., IDS alerts, log review); replacing hardware and restoring data goes beyond identifying the failure. D. Physical is incorrect. Physical controls (locks, guards, cameras) protect the physical environment; replacing a failed component and restoring data is a recovery activity, not physical protection. A. Preventive is incorrect. Preventive controls act before an incident to stop it from happening; here the hardware failure has already occurred. B. Corrective is correct. Corrective controls restore systems to normal operation after an incident — replacing the failed component and restoring data from backup is a textbook corrective action.

Q59: A

A. Redundancy is correct: it is the duplication of critical components — power supplies, network links, servers, sites — so that a backup component can take over when the primary fails, keeping essential services available. B. Encryption is incorrect: it protects data confidentiality and provides no duplicate component to take over after a failure. D. VPN tunnel is incorrect: it provides secure remote connectivity, not duplication of components. C. Load balancing is incorrect: it distributes traffic across multiple active servers for performance and scalability; it is not itself the duplication of a component with a backup standing by to take over.

Q60: A

A (Authentication) is correct: authentication is the process of verifying that a user, device, or system is who it claims to be. It relies on factors such as something you know (a password), something you have (a token or smart card), or something you are (a fingerprint), and it must succeed before any access decision is made. D (Authorization) is incorrect because authorization comes after authentication and determines what an already-identified user is permitted to access or do. C (Accounting) is incorrect because accounting is the third element of AAA, the logging and tracking of what users did and when, used for auditing rather than identity confirmation. B (Encryption) is incorrect because encryption protects the confidentiality of data by transforming it into unreadable ciphertext; it does not confirm anyone's identity.

Q61: C

A. Cross-site scripting is incorrect. XSS injects malicious scripts that execute in other users' browsers; it targets the client side, not backend database queries. C. SQL injection is correct. SQL injection sends crafted input that the application interprets as part of a database query, letting an attacker read, modify, or delete backend data or bypass authentication. B. DNS poisoning is incorrect. DNS poisoning corrupts name-resolution records to redirect users to malicious hosts; it does not manipulate database queries. D. URL spoofing is incorrect. URL spoofing disguises a malicious link as a trusted address to deceive users; it does not send queries to a backend database.

Q62: 1 = A; 2 = D; 3 = C; 4 = B

The correct mapping is: Pharming redirects traffic using DNS poisoning — attackers corrupt DNS cache entries so users are sent to malicious sites even when typing the correct URL. Vishing is social engineering via phone — attackers call targets impersonating legitimate organizations to extract credentials or sensitive information. Logic bomb is a malicious script triggered by a specific condition (e.g., a date, login event, or file deletion), lying dormant until activated. Typosquatting involves registering a domain similar to a legitimate one (e.g., 'micosoft.com') to intercept users who mistype URLs, delivering phishing pages or malware.

Q63: A

A (Ensure ongoing operations during and after a crisis) is correct: a business continuity plan identifies the critical business functions and sets out the people, processes and alternate resources needed to keep them running through a disruption and to restore normal service afterwards. C (Reduce employee turnover in the IT and security teams) is incorrect because staff retention is an HR objective with no role in continuity planning. D (Identify exploitable vulnerabilities in production hosts) is incorrect because finding technical weaknesses belongs to vulnerability management, which may feed the impact analysis but is not the plan's goal. B (Monitor patch compliance across endpoints) is incorrect because patch compliance is a day-to-day operational metric, not a continuity outcome.

Q64: D

A. Security awareness training is incorrect. Awareness training reduces risk from an organization's own users; it does not assess or control the security of third parties. D. Supply chain auditing is correct. Auditing vendors and suppliers, including reviewing their controls, right-to-audit clauses, and independent assessments, directly evaluates and reduces the risk introduced by third parties in the supply chain. B. Whitelisting is incorrect. Application allowlisting restricts which programs can run on a host; it is an endpoint control and does not address third-party or vendor risk. C. Traffic shaping is incorrect. Traffic shaping manages bandwidth and network performance; it has no bearing on third-party risk.

Q65: C

D. RFID swiping is incorrect. "Swiping" is not the standard term for the duplication of RFID tag data. C. RFID cloning is correct. RFID cloning is the act of reading the data from a legitimate tag and writing an identical copy onto another tag so it can be used to impersonate the original. A. RFID duplicating is incorrect. While conceptually similar, "duplicating" is not the recognized Security+ term; the industry-standard term is cloning. B. RFID mirroring is incorrect. Mirroring refers to replicating data stores in real time and is not an RFID attack category.

Q66: D > C > B > A > E

Correct order: 1. Procure the server through the approved acquisition process — the lifecycle begins with acquisition, where security requirements and supplier vetting are applied before the asset enters the environment. 2. Assign an owner and classify the data the server will hold — assignment and accounting establish who is accountable and what protection level the data requires, which drives every later control. 3. Track the server's location, patch level, and configuration while it is in service — monitoring and asset tracking keep the record accurate so the system stays patched, scanned, and in scope for incident response. 4. Sanitize the storage media so that no customer data can be recovered — at decommissioning, wiping, degaussing, or destroying the media eliminates retrievable information according to the data classification. 5. Obtain a certificate of destruction from the disposal vendor and update the records — certification proves disposal was completed and closes the asset's entry, supporting audits and retention requirements. In-service tracking cannot start before the asset exists and has an owner, and certifying destruction before sanitization would document something that has not happened.

Q67: B

B. Typo-squatting is correct. Typo-squatting registers domains that closely resemble a trusted name, using common misspellings or look-alike characters, so users who mistype or trust the familiar-looking address are lured to a malicious site. A. Command injection is incorrect. Command injection runs attacker-supplied operating-system commands through a vulnerable application; it does not rely on imitating a trusted domain. C. ARP spoofing is incorrect. ARP spoofing forges ARP replies on a local network to intercept traffic; it operates at Layer 2 and does not mimic a domain name. D. Session replay is incorrect. Session replay reuses captured session data to impersonate a user; it does not involve a look-alike domain to trick the victim.

Q68: C

C. Policy Engine is correct. In the Zero Trust control plane, the Policy Engine evaluates each access request against policy and renders the grant or deny decision. A. Policy Enforcement Point is incorrect. The PEP sits in the data plane and enforces the decision by establishing or blocking the connection; it does not make the policy decision itself. B. Subject/System is incorrect. The subject or system is the entity requesting access to a resource, not a component that evaluates requests. D. Implicit trust zone is incorrect. It is a data-plane concept describing areas where traffic is trusted by default, something Zero Trust aims to reduce or eliminate, not a decision-making component.

Q69: C

A. A skilled hacker working for a nation-state is incorrect. Nation-state actors are highly resourced and sophisticated, the opposite of a script kiddie. B. An insider using custom exploits is incorrect. Writing custom exploits requires technical skill a script kiddie lacks, and this describes an insider threat. C. An unskilled attacker using pre-built tools is correct. A script kiddie is an inexperienced attacker who runs pre-built tools and scripts written by others, without deep technical understanding. D. A hacktivist promoting political change is incorrect. A hacktivist is defined by political or ideological motivation, not by skill level.

Q70: D

A. Schedule patch timelines is incorrect: patch scheduling is a vulnerability-management task, not a forensic control. B. Track incident trends is incorrect: trend analysis is a reporting activity, not the purpose of chain of custody. D. Document evidence handling is correct: a chain of custody records who collected, accessed, transferred, and stored each piece of evidence and when, preserving its integrity and admissibility. C. Encrypt audit logs is incorrect: encryption protects log confidentiality but is not what chain of custody provides.

Q71: B

C. Allowing access once users are inside the corporate LAN is incorrect: zero trust rejects implicit trust based on network location, so being on the internal LAN grants nothing by itself. B. Requiring re-authentication when accessing each new resource is correct: zero trust follows "never trust, always verify," validating identity and authorization for every resource request rather than once at the perimeter. D. Whitelisting all known MAC addresses is incorrect: MAC filtering is a weak, easily spoofed network control and does not implement per-request verification. A. Disabling multifactor authentication for internal users is incorrect: it weakens verification, the opposite of zero trust, which strengthens authentication everywhere.

Q72: D

A. Certificate authority (CA) is incorrect: in this arrangement the CA issues and signs the certificate after verification is complete; verifying the applicant is delegated to the intermediary component. D. Registration authority (RA) is correct: the RA acts as the intermediary between the applicant and the CA, verifying the applicant's identity and credentials before the CA issues the certificate. B. Certificate signing request (CSR) is incorrect: a CSR is the message containing the applicant's public key and identifying information — it is a data object, not a component that verifies anyone. C. Intermediate CA is incorrect: an intermediate CA is a subordinate certificate authority that signs certificates in the chain below the root; it is not the component that verifies applicant credentials.

Q73: B

B. SDN is correct because software-defined networking virtualizes parts of a physical local network by separating the control plane from the data plane, enabling centralized, programmable network management. D. SDV is incorrect because it is not a recognized networking technology. A. VDI is incorrect because Virtual Desktop Infrastructure virtualizes user desktops, not the local network. C. SD-WAN is incorrect because software-defined WAN applies these principles to wide area networks connecting remote sites, not to a physical local network.

Q74: D

A. WEP is incorrect. WEP (Wired Equivalent Privacy) is an outdated and broken protocol predating WPA3; it uses RC4 encryption with known critical weaknesses. D. SAE is correct. Simultaneous Authentication of Equals replaces the PSK handshake in WPA3, using a Dragonfly key exchange that prevents offline dictionary attacks and provides forward secrecy during authentication. C. OWE is incorrect. OWE (Opportunistic Wireless Encryption) enhances open networks with encryption but does not address handshake authentication specifically. B. PXF is incorrect. PXF is not a defined WPA3 security feature or protocol.

Q75: C

B. Block all attackers is incorrect. A honeypot is a passive decoy meant to be probed and studied; it observes and records attacker activity rather than blocking it. C. Provide threat intelligence is correct. A honeypot mimics a vulnerable server so that attackers interact with it; the resulting logs — tools, IP addresses, and techniques used — yield threat intelligence that defenders apply to harden and detect attacks on production systems. D. Restore data backups is incorrect. Backup and recovery are handled by dedicated backup systems; a honeypot holds no production data to restore. A. Segment VLAN traffic is incorrect. Network segmentation is enforced by switches, VLANs, and firewalls; a honeypot is a deception system, not a segmentation control.

Q76: A

C. CVSS is incorrect. The Common Vulnerability Scoring System rates the severity of a vulnerability; it is a measurement, not a path an attacker uses to reach a target. A. Email phishing link is correct. A threat vector is the means or path an attacker uses to gain access, and a phishing link delivered by email is a classic message-based vector for delivering malware or stealing credentials. D. Password policy is incorrect. A password policy is a preventive administrative control, not an avenue of attack. B. Firewall appliance is incorrect. A firewall is a defensive network control used to filter traffic, not a vector attackers use to get in.

Q77: 1 = C; 2 = A; 3 = D; 4 = B

The correct pairings are: 443 = HTTPS; 22 = SSH; 53 = DNS; 3389 = RDP. Port 443 is used by HTTPS (HTTP over TLS/SSL) — the standard for encrypted web browsing and API communication. Port 22 is assigned to SSH (Secure Shell), providing encrypted remote terminal access; it is also used by SFTP and SCP for secure file transfers. Port 53 is used by DNS (Domain Name System) for name-to-IP resolution, typically UDP for queries and TCP for zone transfers and large responses. Port 3389 is used by RDP (Remote Desktop Protocol), Microsoft's graphical remote desktop service for Windows — it is a frequent target for brute-force attacks and exploitation, making its exposure to the internet a high-risk configuration.

Q78: B

A. Boot from HDD and store data on SSD is incorrect because it speeds up file access but leaves boot operations on the slower HDD. C. Boot from SSD and store data on HDD is incorrect because it speeds up booting but leaves file read/write operations on the slower HDD. B. Boot from SSD and store data on SSD is correct because it maximizes both boot responsiveness and file read/write responsiveness, which the scenario prioritizes over cost and capacity. D. Boot from HDD and store data on HDD is incorrect because both booting and file operations would run on the slower medium.

Q79: A

D. Social engineering is incorrect. Social engineering is an attack category involving human manipulation — it has no role in CVSS scoring. A. Exploitability is correct. In CVSS (Common Vulnerability Scoring System), the exploitability metrics describe how easily a vulnerability can be leveraged by an attacker. These sub-metrics include Attack Vector, Attack Complexity, Privileges Required, and User Interaction. A high exploitability score indicates the vulnerability is easy to exploit remotely without special conditions. C. SQL injection is incorrect. SQL injection is a specific attack technique — not a CVSS scoring metric. B. Buffer overflow is incorrect. Buffer overflow is a vulnerability class and attack type, not a component of the CVSS framework.

Q80: C

A. "The cloud network configuration does not require any servers" is incorrect because serverless still runs on servers; they are simply provisioned and managed by the cloud provider. C. "Server resources of the cloud are inconspicuous to the end-user" is correct because in serverless computing the provider manages the underlying servers and they are invisible to the user, who only writes code and defines trigger events. D. "Servers are run as VMs" is incorrect because that describes traditional virtualization, not the serverless model. B. "All appliances are virtual and do not interact with physical servers" is incorrect because serverless workloads ultimately execute on the provider's physical servers.

Q81: B

C. Threat hunting is incorrect. Threat hunting proactively searches an organization’s own environment for signs of hidden compromise; it is not a review of a vendor’s documentation. D. Vulnerability assessment is incorrect. A vulnerability assessment scans systems for technical weaknesses; reviewing documented policies and compliance posture is a governance evaluation, not a technical scan. B. Vendor risk management is correct. Evaluating a third-party provider’s security policies, procedures, and compliance posture before contracting is the assessment step of vendor (third-party) risk management. A. Digital forensics is incorrect. Digital forensics collects and analyzes evidence related to a security incident; it is not used to evaluate a prospective vendor.

Q82: A

D. Rootkit is incorrect. A rootkit hides its presence and maintains privileged access on a host; it does not self-propagate across a network on its own. A. Worm is correct. A worm is self-replicating malware that spreads automatically from system to system across a network — for example by exploiting a service vulnerability — without any user having to open a file or click a link. B. Trojan is incorrect. A Trojan is disguised as legitimate software and relies on a user to run it; it does not spread by itself. C. Spyware is incorrect. Spyware covertly collects information about a user; its propagation typically depends on another delivery method rather than autonomous network spreading.

Q83: B

B is correct (Maintaining the baseline by monitoring for configuration drift): a baseline is a living standard, not a one-time template. After deployment, systems must be re-validated regularly with configuration-compliance scanning so that deviations such as new services or changed registry values are detected and corrected promptly. A is incorrect (Establishing the baseline from a recognized benchmark) because the team did establish it; the hardened image was built from a benchmark. D is incorrect (Deploying the baseline through centralized configuration tools) because deployment also happened; Group Policy pushed the image to every server. C is incorrect (Sandboxing the servers so that new services cannot be installed) because sandboxing isolates untrusted code for analysis; it is not a baseline lifecycle activity and would not reveal drift in registry settings.

Q84: B

B is correct (Virtual machine escape): VM escape occurs when a compromised guest breaks the hypervisor's isolation to reach the host or neighboring VMs. C is incorrect (Resource reuse): resource reuse is when leftover memory or storage from one tenant is exposed to another, not a breakout from the guest. A is incorrect (Race condition): a race condition exploits timing between a check and a use of a resource, which is unrelated to hypervisor isolation. D is incorrect (Directory traversal): directory traversal uses path sequences to read files outside a web root, not to escape virtualization.

Q85: B > D > F > E > A > C

Correct order: 1. A user opens a phishing email attachment, giving initial access — the intrusion usually starts with a message-based vector. 2. The malware executes and installs on the host — the payload runs and gains a foothold. 3. The malware establishes a command-and-control channel — it reaches out for instructions. 4. The attacker moves laterally to additional systems — access is expanded across the network. 5. Files are encrypted across the reachable systems — the payload locks data on every system it can reach. 6. A ransom demand is displayed — the victim is told to pay to recover access.

Q86: A

A. Correct — data masking creates a copy of the original data in which sensitive elements are obfuscated (for example, replaced or partially hidden), preserving a usable, structurally similar substitute for processes that do not need the real values. B. "Data protecting" is not a defined data-security method. C. "Data tokening" is not the correct term; tokenization replaces data with a token that maps to the original stored elsewhere, a different method from copying-and-obfuscating. D. "Data covering" is not a recognized data-security method.

Q87: C

B. Block known threats is incorrect. Blocking known threats is the job of a firewall, IPS, or antivirus; a vulnerability scan reports issues but does not block traffic. C. Identify misconfigurations and weaknesses is correct. A vulnerability scan enumerates hosts and services and compares them against a database of known flaws and insecure settings, producing a prioritized list of weaknesses to remediate. A. Exploit system vulnerabilities is incorrect. Actively exploiting weaknesses is penetration testing; a vulnerability scan identifies without exploiting. D. Prevent data exfiltration is incorrect. Preventing data from leaving the organization is the role of data loss prevention (DLP), not the goal of a vulnerability scan.

Q88: A

C. Cross-site request forgery is incorrect. CSRF tricks an authenticated user's browser into sending unwanted requests; it does not inject code through a web form. A. Input validation flaw is correct. When a web form fails to validate or sanitize input, attackers can submit unexpected code (such as SQL injection or cross-site scripting payloads); the underlying weakness is improper input validation. D. URL redirection is incorrect. Unvalidated redirects send users to untrusted sites; they are not about injecting code into a form field. B. Packet sniffing is incorrect. Sniffing passively captures network traffic and involves no code injection into a web form.

Q89: A

A (SLE) is correct: single loss expectancy is the expected monetary loss each time a specific risk occurs. It is calculated as SLE = asset value (AV) x exposure factor (EF), where the exposure factor is the percentage of the asset's value that would be lost in one incident, so it is precisely the figure Emiliano needs. D (AV) is incorrect because asset value is only an input to the calculation, the worth of the asset itself, not the loss expected from a single event. C (ARO) is incorrect because the annualized rate of occurrence expresses how many times per year the risk is expected to happen, a frequency rather than a monetary amount. B (ALE) is incorrect because annualized loss expectancy multiplies SLE by ARO to give the expected loss per year across all occurrences, not the loss from one occurrence.

Q90: C

C (A benign activity incorrectly flagged as malicious) is correct: a false positive is an alert raised on something harmless, and although it is safer than missing an attack, a high false positive rate drives alert fatigue and wastes analyst time. A (A legitimate alert that analysts close without reviewing it) is incorrect because that is a triage or process failure on a true positive, not a misclassification by the tool. B (A real threat that the detection tool fails to catch) is incorrect because that defines a false negative, the dangerous opposite case. D (A phishing attempt that successfully steals a user's credentials) is incorrect because it describes the outcome of an attack - a security incident to be handled - and not a category of detection accuracy at all.